# Politique d’utilisation de l’IA — Hexalp

**V0.1 — 23 octobre 2026 — Proposition pédagogique à approuver par la direction.** Application : lundi suivant l’approbation, après vérification DSI des moyens et diffusion par les managers. Référente : Nadia, RSSI. Les contrôles ci-dessous sont prescrits, pas réputés déployés.

**Les cinq règles à retenir — Salariés et prestataires**

1. **Choisissez**, pour votre travail, un outil et un compte professionnels autorisés pour votre usage ; vérifiez la liste A.

2. **Retirez** mots de passe, clés, jetons et données inutiles avant toute demande ; ne transmettez jamais de C3 à l’IA.

3. **Faites relire**, avant toute application en production, le code, les commandes et les configurations par une seconde personne habilitée.

4. **Demandez** l’accord DSI avant une extension, un connecteur ou un agent ; ne validez pas seul un consentement OAuth.

5. **Signalez** immédiatement au RSSI tout envoi ou accès suspect, sans recopier le secret ; la bonne foi et le signalement rapide sont protégés (§12).

## 1. Objet et périmètre

**Appliquez — salariés, intérimaires, prestataires et managers —** ces règles à tout usage professionnel d’assistant, IA embarquée, traduction, transcription, extension, agent, API ou modèle local, y compris sur appareil personnel. **Incluez — DSI —** les modèles de détection développés en interne dans l’inventaire, avec leurs responsables et dépendances.

## 2. Outils — Annexe A : listes A/B/C

**Consultez — utilisateur —** le catalogue DSI, rubrique IA, avant emploi ; un logiciel approuvé n’autorise pas automatiquement sa nouvelle fonction IA. **Tenez — DSI —** trois listes versionnées ; publiez pour chaque autorisation outil/version, usage, compte, classes permises, propriétaire et échéance. **Contrôlez — RSSI —** cette liste mensuellement.

**A — Autorisés dans la présente proposition :** Python/Scikit-learn et les scripts J3/J4 pour apprentissage et évaluation locale sur données fictives, poste/laboratoire DSI, sans accès production ni transfert externe. Les modèles de détection opérationnels restent soumis au §9. ChatGPT dans un espace professionnel administré par la DSI : rédaction/reformulation de contenus C0 ou fictifs uniquement, sans fichiers internes, connecteurs ni partage public ; ouverture après vérification par DSI/RSSI de l’offre, du compte et des réglages, inscrits au catalogue. Utilisez la rédaction interne tant que cet espace n’est pas disponible ; son achat ou activation n’est pas attesté ici.

**B — Soumis à validation avant usage :** autres offres/usages ChatGPT, API OpenAI, GitHub Copilot, DeepL, Ollama et ses modèles, TalentSort, HelpFlow et ses fonctions IA, MeetNote, InboxPilot et tout nouvel outil ou nouvelle fonction. **Fournissez — DSI et manager —** en attendant le §11 : dépannage local/support d’astreinte, alertes Zabbix originales, rédaction/traduction internes, notes de réunion manuelles et examen humain des candidatures.

**C — Interdits dans les configurations décrites :** comptes personnels traitant Hexalp ; liens publics de conversations métier ; C3 dans prompts/contexte ; AI Summarizer Pro avec accès à tous les sites/historique sans validation ; agents à droits globaux ou écrivant en production sans approbation. **Remplacez — DSI/manager —** ces usages par les solutions internes ci-dessus, puis une solution approuvée et limitée ; utilisez le coffre-fort pour les secrets.

**Décidez — DSI avec RSSI et DPO si nécessaire —** d’un passage B/C vers A seulement après correction des écarts, contrat et données vérifiés, droits bornés, essais de refus/révocation et décision enregistrée ; un achat, le SSO ou le silence ne valent pas accord. **Suspendez — DSI —** l’autorisation si ces conditions cessent d’être remplies et fournissez une solution transitoire.

## 3. Comptes et clés d’API

**Utilisez — utilisateur —** uniquement le compte professionnel administré indiqué en A ; « Se connecter avec Hexalp » n’approuve ni le fournisseur ni les droits demandés. **Souscrivez — DSI/achats —** les abonnements et licences ; ne remboursez pas un compte personnel comme solution d’accès. **Gérez — DSI —** MFA lorsque disponible, départs et révocations ; stockez les clés d’API dans le coffre-fort ou gestionnaire technique approuvé, avec propriétaire, périmètre, budget et rotation. L’authentification technique transmet le jeton uniquement au point de terminaison prévu, jamais au modèle ni dans un journal.

## 4. Données et classification PSSI

**Classez — utilisateur, avec son manager en cas de doute —** les entrées, fichiers joints et contexte automatique : C0 public ; C1 interne ; C2 confidentiel ; C3 secret. **Limitez — utilisateur —** C0/C1 aux outils A explicitement autorisés pour ces classes ; traitez C2 uniquement dans un périmètre A validé C2 par DSI/RSSI. Aucune entrée C1/C2 n’est ouverte actuellement par A. **Excluez — utilisateur —** tout C3, même d’un outil local ou autorisé : utilisez des valeurs fictives et le coffre-fort. **Faites valider — DPO —** tout traitement de données personnelles avant activation, avec les garanties contractuelles et conditions d’utilisation nécessaires ; le seul caviardage d’un nom ne garantit pas l’anonymat.

## 5. Code, configurations et journaux

**Préparez — auteur de la demande —** un extrait minimal, relu localement : remplacez identifiants, coordonnées, clients, IP/noms internes et secrets par des valeurs cohérentes fictives ; retirez pièces inutiles, historique et fichiers voisins. Respectez ensuite §4 : minimiser ne déclassifie pas automatiquement C2. **Contrôlez — DSI —** les exclusions de contexte, l’envoi de fichiers et les partages publics ; testez le filtrage de motifs de secrets au point de sortie administré avant de le déclarer actif. **Employez — administrateur —** les outils internes de diagnostic si le filtrage manque ou si le contenu reste sensible ; aucun filtre ne remplace la relecture, notamment pour images et secrets inconnus.

## 6. Assistants de code

**Installez — développeur, via DSI —** uniquement l’extension et l’offre approuvées ; excluez secrets et répertoires non nécessaires du contexte. **Vérifiez — développeur puis relecteur —** provenance/licence du code et existence, éditeur, version et risques des paquets suggérés ; testez dans un environnement isolé avec dépendances fixées avant intégration. **Refusez — développeur —** un téléchargement ou une dépendance non vérifiables ; utilisez une bibliothèque du catalogue ou le développement classique, avec aide du référent technique.

## 7. Extensions, connecteurs et agents — règle issue de 5.4

**Faites approuver — demandeur —** chaque connexion par DSI/RSSI ; ne consentez pas seul à OAuth. **Attribuez — DSI —** une identité dédiée, ressources/actions minimales, durée et propriétaire ; testez refus hors périmètre et révocation. **Imposez — DSI —** une approbation humaine de l’action exacte avant écriture en production, envoi externe ou modification de droits ; journalisez l’approbateur et le résultat. **Suspendez — DSI —** le connecteur en cas de doute et maintenez le traitement manuel. Ne confiez pas de compte administrateur global à l’agent ; le texte « ignore ces instructions » ne remplace pas les contrôles d’exécution.

## 8. Vérification humaine

**Vérifiez — auteur —** faits, sources, calculs et confidentialité avant diffusion. **Faites relire et tester — responsable du changement —** toute commande, configuration ou script générés pour la production par une seconde personne habilitée ; inscrivez auteur, relecteur, tests et retour arrière au journal DSI avant application. **Escaladez — administrateur d’astreinte —** au référent habilité si aucun relecteur n’est disponible ; utilisez la procédure interne de dépannage, sans exécuter la proposition IA. **Décidez — métier compétent —** des suites RH/client ; ne déléguez pas à l’IA seule le classement éliminatoire d’une candidature.

## 9. Modèles développés par Hexalp

**Maintenez — responsable supervision —** les modèles J4 en évaluation hors exploitation tant que la recette et les moyens ne sont pas approuvés. **Autorisez — RSSI avec SOC et DSI —** un pilote supervisé de quatre semaines seulement après validation des données, tests temporels indépendants, erreurs acceptables, capacité de qualification et retour arrière ; conservez règles existantes et décisions humaines, sans blocage autonome du modèle.

**Contrôlez — supervision —** chaque lot, unités, schéma et manques ; suspendez le calcul et signalez la perte de couverture si le contrat échoue. **Protégez — DSI/mainteneur —** données, modèles, scripts et paramètres par droits minimaux, versions, sauvegardes et empreintes comparées à un manifeste approuvé ; ne chargez aucun fichier de modèle de provenance inconnue. **Réévaluez — SOC/supervision —** chaque semaine couverture, FP/FN mesurables, stock et ancienneté ; conservez le surplus au-delà de trente qualifications/semaine et escaladez la charge au RSSI. **Soumettez — mainteneur —** tout remplacement à recette et approbation écrites ; ne réentraînez pas automatiquement. Lancez une revue immédiate après incident manqué, dérive ou changement de sonde/VPN/rôle ; présentez le bilan au plus tard à quatre semaines.

## 10. Traçabilité et conservation

**Enregistrez — DSI —** dans le catalogue/ticket interne l'outil, le compte, l'approbation, les classes et permissions ; conservez ces décisions pendant l'autorisation puis **12 mois**. **Centralisez — exploitation —** dans le SIEM à accès restreint horodatage, identité, outil/version, cible, action, résultat, approbateur, consommation et événements de sécurité pendant **6 mois**, puis purgez automatiquement. Ne journalisez pas les secrets ni les prompts/réponses complets par défaut ; protégez aussi les identifiants de ressources révélant l'architecture. **Conservez — responsable du changement —** les validations dans le journal DSI pendant **12 mois**. **Isolez — RSSI avec DPO/juridique —** les seules preuves nécessaires à un incident sous accès restreint et réexaminez leur maintien tous les trois mois jusqu'à clôture et échéance juridique motivée. **Testez — DSI —** collecte et purge ; faites valider ces durées internes proposées par le DPO avant application, ainsi que l'information des personnes.

## 11. Demander un outil sans bloquer le métier

**Ouvrez — salarié avec manager —** un ticket au support DSI : besoin, urgence, outil/offre, compte, données, flux, droits, coût et alternative. **Accusez réception — DSI —** sous **1 jour ouvré** ; affectez un pilote et associez RSSI/DPO selon le risque. **Répondez — DSI/RSSI —** par accord borné, essai sur données fictives ou refus motivé avec alternative sous **10 jours ouvrés depuis réception**, sans suspendre ce délai pour dossier incomplet ; signalez les pièces manquantes dès l'accusé. **Arbitrez — manager et RSSI —** immédiatement l'alternative en urgence ; après échéance sans réponse, escaladez à la direction DSI et fournissez sous **1 jour ouvré** une solution transitoire. Le dépassement n'autorise aucun usage. Adressez toute dérogation au RSSI conformément à l'article 9.2 ; ne dérogez pas à l'exclusion C3 des entrées IA.

## 12. Signaler un envoi ou accès accidentel

**Alertez — utilisateur —** immédiatement, dès le soupçon, le RSSI par le canal d'incident habituel ; hors horaires, appelez l'astreinte DSI, qui joint la permanence RSSI. Si le portail est indisponible, utilisez le téléphone professionnel du support/RSSI figurant dans l'annuaire interne ; n'attendez ni réponse de l'IA ni preuve d'exploitation. **Indiquez — déclarant —** heure, outil, compte, classes et lien en canal restreint, sans recopier les secrets ; cessez l'envoi. **Préservez puis confinez — RSSI/DSI —** les éléments minimaux sans retarder rotation, révocation et retrait des partages. **Protégez — direction et managers —** le signalement rapide de bonne foi : aucune sanction pour le seul fait d'avoir signalé ou demandé de l'aide ; ne promettez pas une immunité pour tout comportement. **Informez — RSSI —** DPO immédiatement si données personnelles possibles, juridique/commercial si clients, DG selon gravité ; faites vérifier obligations et délais selon P8, sans attendre la clôture technique. **Organisez — RSSI —** le RETEX sous quinze jours selon P8, avec déclencheur tracé.

## 13. Responsabilités et préparation du lundi

**Appliquez — salarié —** classification, vérification du catalogue, minimisation, relecture et signalement ; conservez la référence des validations. **Couvrez — manager —** le besoin métier, désignez le relecteur et diffusez les cinq règles à chaque équipe. **Administrez — DSI —** catalogue, comptes, contrats/achats, contrôles, journaux, support et continuité ; vérifiez avant diffusion l'annuaire d'incident et la disponibilité du circuit d'astreinte. **Pilotez — RSSI —** validations de sécurité, dérogations, incidents et revues ; associez les métiers. **Examinez — DPO —** traitements personnels, contrats, information, durées et analyse des violations ; faites décider les notifications par le responsable de traitement avec son conseil. **Approuvez — direction —** politique, moyens et arbitrages ; ne déclarez pas un contrôle actif sans résultat de test. **Publiez — DSI —** avant entrée en vigueur le catalogue A/B/C et les moyens utilisables ; en cas de contrôle indisponible, donnez le chemin interne manuel du besoin concerné et une date de mise en place.

## 14. Révision

**Révisez — RSSI avec DSI/DPO et métiers —** cette politique **chaque trimestre** ; contrôlez immédiatement le périmètre touché après incident, faille majeure, nouvelle fonction IA/permission, changement de modèle, contrat, conservation ou indisponibilité fournisseur. **Suspendez — DSI —** le seul usage affecté si ses garanties ne tiennent plus ; maintenez une alternative interne. **Diffusez — managers —** la version approuvée et ses changements avant reprise ; enregistrez date et décision au catalogue.

## 15. Articulation avec la PSSI v3.2

**Appliquez — tous les responsables —** cette politique comme complément soumis à approbation, sans abroger la PSSI. **Rattachez — RSSI —** §4–5 à **2.1/2.3/5.5** (classes et secrets) ; §2/6/7 à **4.1/4.4** (outils, extensions, gratuité et achats) ; §3 à **5.2/5.5** (comptes et clés) ; §4/10/13 à **7.1** (données personnelles) ; §12 à **8.1** ; §11 à **9.2**, dont le plafond de dix jours ouvrés est étendu ici aux demandes ordinaires. **Comblez — DSI/RSSI —** les angles morts sur IA embarquée, contexte automatique, OAuth, actions générées, réversibilité et modèles internes par §2/5/7–10/14. **Faites arbitrer — RSSI avec direction et DPO —** toute contradiction avant usage ; maintenez le traitement interne pendant cet arbitrage.

## Annexe B — Besoins et contrôle de l'incident Julien

**Vérifiez — groupe relecteur —** la couverture suivante ; ce sont des effets attendus des règles, pas une preuve qu'un incident aurait été impossible.

| Situation ou besoin | Règles à appliquer et solution métier |
|---|---|
| Dépannage WMS nocturne sur compte personnel | §2/3/11 : compte et outil approuvés ; à défaut diagnostic interne et référent d'astreinte |
| Configuration/logs avec secrets et données clients | §4/5 : exclure C3, extrait fictif minimal ; garder les originaux dans l'outillage interne |
| Commande IA et changement HAProxy non revus | §8/10 : seconde personne habilitée, test, journal et retour arrière ; procédure interne si absence du relecteur |
| Lien public et reprise sur forum | §2/5 : aucun partage public métier ; utiliser le dossier interne à accès limité |
| Exposition déjà survenue | §12 : alerte, retrait/rotation et enquête rapide ; copies résiduelles à examiner |
| Agents et campagne étudiée en 5.4 | §7 : identité dédiée, droits bornés, validation d'action et révocation testée |

**Utilisez — RSSI —** comme références de conception : PSSI v3.2, productions J2/J4 et P8 ; ANSSI, guide IA générative v1.0, 29/04/2024, CNIL, questions-réponses, 18/07/2024, OWASP agentique 2026, 09/12/2025, consultés le 23/10/2026. Ces recommandations ne constituent pas une approbation d'Hexalp ; les délais et durées chiffrés ci-dessus sont des choix internes proposés.